

RELATÓRIO DE EXPLORAÇÃO TÉCNICA - ELITE 2026

Alvo: ih777c.com

Autor: Seth VII

Data: 07 de Janeiro de 2026

Classificação: CONFIDENCIAL / PROVA DE CONCEITO

1. Introdução

Este documento detalha a análise de segurança e a exploração de vulnerabilidades realizadas contra a infraestrutura do site `ih777c.com`. O objetivo da operação foi identificar falhas críticas que permitissem a obtenção de credenciais, privilégios especiais ou persistência global no sistema.

2. Metodologia e Ferramentas

A operação seguiu o framework de **Kill Chain de Elite**, utilizando ferramentas avançadas do projeto *Ascensão - Cultivo Digital v4.0* e técnicas de análise manual.

Ferramentas Utilizadas:

- WebVuln Analyzer [ELITE]:** Scanner dinâmico para identificação de vulnerabilidades web modernas.
- Elite API Manipulator:** Ferramenta para interceptação e modificação de requisições de API.
- JWT Exploit Module:** Script customizado para reconstrução e bypass de tokens JWT.
- Service Worker Analyzer:** Ferramenta de análise de lógica de persistência em background.

- **Custom Python Exploits:** Scripts desenvolvidos sob demanda para ataques de força bruta e IDOR.
-

3. Passo a Passo da Operação

Fase 1: Reconhecimento e Mapeamento

Iniciamos com uma varredura passiva e ativa para identificar a infraestrutura. O alvo utiliza **Cloudflare** como proteção de borda e **Alibaba Cloud Function Compute** no backend.

- **Endpoint de API Identificado:** `https://api2.ycyd123.com`
- **Assets Críticos:** `/assets/index-BSzUKgyW.js` e `sw.produce.min.2.1.6.js`.

Fase 2: Análise de Código e Extração de Segredos

Através de uma análise estática profunda do arquivo JS principal, extraímos informações que nunca deveriam estar expostas no frontend:

- **Fragmentos de Tokens JWT:** Identificamos dados do usuário `Jose Regi`.
- **Chaves de API:** 64 strings de 32 caracteres que servem como segredos ou chaves de integração.
- **Lógica de Domínios:** O Service Worker revelou uma lista de domínios de backup para garantir a persistência da operação caso o domínio principal seja derrubado.

Fase 3: Reconstrução de Sessão (JWT Hijacking)

Utilizando os fragmentos base64 encontrados, reconstruímos o payload do token do usuário `Jose Regi`.

- **Dados do Token:** JTI `bd187770-2c99-4fbf-ba10-3760827e11c`, válido até Janeiro de 2026.
- **Vulnerabilidade:** Exposição de PII (Informações Pessoais Identificáveis) e tokens de sessão em código-fonte público.

Fase 4: Testes de Exploração Ativa

Desenvolvemos scripts para testar:

1. **JWT Bypass:** Tentativa de uso do algoritmo `none` para elevar privilégios.
2. **Brute-Force de Assinatura:** Teste das 64 chaves encontradas contra a assinatura HS256.
3. **IDOR (Insecure Direct Object Reference):** Manipulação de parâmetros de ID para acessar dados de terceiros.

4. Vulnerabilidades Identificadas

Vulnerabilidade	Impacto	Descrição Técnica
Exposição de Segredos	CRÍTICO	Tokens e chaves de API hardcoded no frontend.
Falha de CORS	ALTO	Configuração <code>access-control-allow-origin: *</code> na API de backend.
Vazamento de Sessão	ALTO	Tokens de usuários reais persistidos em arquivos JS públicos.
Persistência Global	MÉDIO	Lógica de troca automática de domínios via Service Worker.

5. Conclusão e Recomendações

A infraestrutura do `ih777c.com` apresenta falhas graves de design. A exposição de segredos no frontend anula as proteções do Cloudflare, pois permite que um atacante simule tráfego legítimo com credenciais reais.

Recomendações:

1. Remover todos os segredos e tokens do código frontend.
2. Implementar uma política de CORS restritiva na API.

3. Utilizar algoritmos de assinatura assimétrica (RS256) para JWT.
4. Ofuscar a lógica do Service Worker para impedir o mapeamento da infraestrutura de backup.

Assinado,

Seth VII

Especialista em Segurança Ofensiva